Proposal Experiment Workflow

Christopher Wiggins

Experimental Workflow and Testbed Methodology

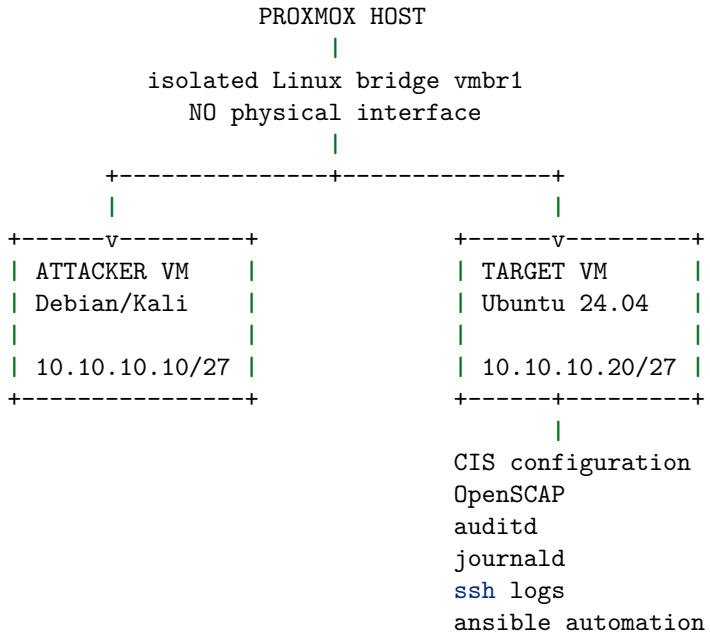
The proposed research will use a controlled, reproducible virtualized testbed to experimentally evaluate relationships between Linux security configuration recommendations and defined cybersecurity attack outcomes. The initial pilot will focus on a single Linux distribution, a single CIS Benchmark version and profile, one defined attack scenario, and a small set of selected CIS recommendations. The purpose of the pilot is not to assume that CIS recommendations prevent particular attacks, but to determine experimentally whether individual recommendations produce measurable changes in attack outcomes, operational behavior, and observable system evidence.

The initial pilot will focus on Ubuntu 24.04 LTS, one identified CIS Benchmark version and profile, one defined attack scenario, and a limited number of selected CIS recommendations. The methodology is designed to determine not only whether CIS hardening as a whole changes an attack outcome, but also which individual recommendations materially contribute to that outcome, which depend on other controls, and what operational consequences accompany those changes.

Virtual Testbed

The experimental environment will be hosted on a dedicated Proxmox Virtual Environment (Proxmox VE) server. Proxmox will provide virtual-machine isolation, repeatable system restoration, virtual networking, and snapshot management.

The initial testbed will contain two virtual machines connected through an isolated virtual network:



1. Target VM: An Ubuntu 24.04 LTS Server system representing the system being evaluated. The target will contain OpenSSH, OpenSCAP, Linux Audit, system logging facilities, and the configuration and security assessment tools required by the experiment.

2. Attacker/Test VM: A separate Kali Linux virtual machine used to conduct authorized attack simulations, legitimate-access tests, and external observations of the target.

The experimental network will have no direct connection to production university systems or public networks during attack testing. All accounts, credentials, addresses, and services used during experimentation will be created specifically for the research environment.

A third data-collection or orchestration system may be introduced as the project develops. However, the

initial pilot will rely primarily on standard Linux logging mechanisms and experiment scripts so that the feasibility of the study does not depend on the availability of a specialized provenance platform.

Baseline Target Configuration

Two principal reference states will be maintained.

The first will be a stock Ubuntu baseline, representing the operating system in a minimally modified or default configuration appropriate to the selected attack scenario. This system will provide an external comparison for determining the overall effect of CIS hardening.

The second and more important experimental reference will be a CIS Level 2 hardened golden image. This system will be created from the same Ubuntu installation, hardened according to the selected CIS Benchmark version and profile, and evaluated to verify that the intended hardened configuration has been successfully applied.

The resulting relationship will be:

Stock Ubuntu → Apply CIS Level 2 Hardening → Verify Configuration → CIS Level 2 Golden Image

Once the hardened system has been validated, a Proxmox snapshot will preserve it as the canonical hardened reference state. This snapshot will not be directly modified during experimentation. Instead, experimental conditions will be derived from the validated golden image.

This design ensures that experimental systems share the same operating system version, kernel, packages, users, services, instrumentation, and unrelated security settings. Experimental differences can therefore be limited to the selected CIS recommendations under investigation.

Control Ablation Method

The primary experimental method will use systematic control ablation. In this approach, the experiment begins with the complete validated hardened configuration and selectively removes or weakens individual CIS recommendations.

For example, if two recommendations are designated Control A and Control B, the primary experimental conditions will be:

Condition	Control A	Control B	Remaining Controls
H0 - hardened	enabled	enabled	enabled
H1 - A ablated	less restrictive	enabled	enabled
H2 - B ablated	Enabled	less restrictive	enabled
H3 - A+B ablated	Less restrictive	less restrictive	enabled

A separate stock Ubuntu condition will provide an external comparison:

Condition	Description
U0 - stock baseline	default ubuntu configuration
H0 - hardened ref.	validated CIS level 2 configuration
H1	CIS Level 2 except control A
H2	CIS level 2 except Control B
H3	CIS level 2 except Controls A and B

This design provides two complementary forms of evidence.

First, comparing U0 with H0 measures the aggregate effect of the hardened configuration against the selected attack.

Second, comparing H0 with H1, H2, and H3 measures the marginal and conditional contribution of individual CIS recommendations within an otherwise hardened environment.

This distinction is important because security controls may overlap. Removing one control may produce no observable change because another hardened configuration still prevents the attack. Such a result will not automatically be interpreted as evidence that the removed control is ineffective. Instead, it may indicate that the control's effect is redundant or conditional under the tested configuration.

CIS Recommendation Selection and Mapping

Candidate recommendations will be selected from a specific CIS Benchmark version and profile applicable to the target operating system. Each candidate recommendation will be mapped to a proposed attack relationship before experimentation.

For each recommendation, the research will document the exact CIS recommendation identifier and title, CIS rationale, affected configuration parameter, recommended secure state, deliberately less restrictive comparison state, hypothesized relationship to the attack, expected attack outcome, expected operational effect, supporting technical evidence, and confidence in the proposed relationship.

MITRE ATT&CK will be used to characterize the attack behavior represented by the experiment. CWE, CVE, and CVSS information will be incorporated only when a defensible relationship exists. A CIS recommendation addressing a configuration weakness will not automatically be associated with a CVE or CVSS score.

This mapping stage produces a testable hypothesis rather than assuming that the relationship described by the benchmark is experimentally established.

Experimental Run Procedure

Each experiment run will follow the same controlled sequence:

1. Restore the appropriate validated reference snapshot.
2. Assign a unique experiment identifier.
3. Apply the control-ablation configuration required by the assigned experimental condition.
4. Verify that the selected controls are in the intended state.
5. Verify that unrelated hardened controls remain unchanged.
6. Restart or reload affected services where necessary.
7. Confirm that required services are operational.
8. Perform the approved legitimate-use test.
9. Execute the authorized attack scenario from the attacker/test VM.
10. Determine the attack outcome using an independent ground-truth mechanism.
11. Collect relevant authentication, system, audit, and service logs.
12. Record selected operational and performance measurements.
13. Preserve all configuration, attack, ground-truth, and logging artifacts.
14. Reset the target before beginning the next experimental run.

Experimental conditions will be executed in randomized order when practical to reduce the possibility that temporal or environmental factors systematically affect one condition.

Each primary condition will be repeated at least five times. Where automation and available time permit, ten repetitions per condition will be conducted.

Configuration Verification

Configuration state will be treated as an experimental measurement rather than assumed from successful execution of a configuration script.

OpenSCAP and direct configuration checks will be used to establish that the system was in the intended state at the time of each experiment.

For the full hardened reference, the experiment will verify that the selected CIS Level 2 configuration is present.

For an ablation condition, verification will establish both that:

1. the selected recommendation was successfully changed to the intended comparison state; and
2. unrelated controls remained in their hardened states.

The experimental chain therefore becomes:

CIS Recommendation → Hardened Configuration → Controlled Ablation → Configuration Verification → Attack Execution → Observed Outcome

This approach strengthens causal interpretation by minimizing configuration differences between experimental conditions.

Independent Ground Truth

Attack success or failure will be established independently of the logging mechanisms being evaluated.

For an SSH-based experiment, successful access may be confirmed through a combination of SSH client exit status, establishment of an authenticated session, execution of a harmless predefined command, and creation of an experiment-specific marker on the target.

The experiment will therefore maintain two distinct forms of evidence:

Ground Truth: Independently established evidence describing what actually occurred.

System Evidence: Authentication, journal, audit, process, and other system records describing what the target reported.

Separating ground truth from system evidence allows the project to evaluate both the security effect of a configuration and the accuracy of the evidence produced during the event.

Legitimate-Use and Operational-Impact Testing

Every experimental condition will also be evaluated for its effect on legitimate system operation.

A dedicated approved test account will perform the intended legitimate operation under each condition. Measurements will include authentication success, shell or command execution success, login completion time, service availability, authentication errors, unexpected connection termination, required manual intervention, and difficulty associated with reversing the configuration.

This provides a second experimental dimension:

Security Effectiveness versus Operational Cost

A recommendation that prevents an attack without interfering with legitimate operation represents a different outcome from a recommendation that prevents the same attack only by substantially degrading expected system functionality.

- Interaction Between Security Controls

The hardened-reference methodology explicitly recognizes that CIS recommendations may not operate independently.

For example, disabling one authentication-related control may not change an attack outcome if another Level 2 control independently prevents the same attack. Conversely, disabling two controls simultaneously may expose an attack path that remains blocked when either control is enabled.

The H1, H2, and H3 conditions therefore allow the experiment to distinguish between individual and combined effects.

If removing Control A alone produces no change, removing Control B alone produces no change, but removing both produces a repeatable change in attack outcome, the evidence suggests an interaction or redundancy between the controls rather than demonstrating that either control is individually ineffective.

This interaction analysis is an important reason for retaining combined ablation conditions.

Logging and Provenance Evaluation

Each experimental run will collect available evidence from SSH authentication logging, the system journal, Linux Audit, and relevant process or service events.

The collected evidence will be compared against independently established ground truth to determine whether:

- configuration changes were observable;
- authentication attempts were recorded;
- successful and unsuccessful access was represented correctly;
- resulting shell or process activity was visible;
- expected events were missing;
- unrelated events were incorrectly associated with the attack;
- experimental failures could be distinguished from successful security controls; and
- the recorded event sequence was sufficient to explain why an attack succeeded or failed.

Additional provenance instrumentation may be incorporated in later phases of the research, but the initial experiment will establish a baseline using standard Linux evidence sources.

Experimental Data Management

Every experimental run will receive a unique identifier encoding the platform, attack scenario, condition, and repetition. For example:

`UBU24-SSH-C2-R04`

Each run will generate both structured measurements and supporting raw artifacts.

The structured dataset will include the experiment identifier, platform information, CIS Benchmark and recommendation identifiers, configuration state, verification results, attack scenario and ATT&CK mapping, attack outcome, shell-access status, number of attempts, time to outcome, legitimate-access results, operational measurements, logging results, validity of the experimental run, and relevant notes.

Raw artifacts will include OpenSCAP results, configuration-verification output, authentication logs, system journal records, Linux Audit records, attack-tool output, legitimate-access results, and other supporting evidence.

Failed experimental runs will remain part of the research record and will be explicitly distinguished from attacks that were successfully blocked by the tested configuration.

Experiment Automation and Reproducibility

The experimental framework will progressively automate the complete test lifecycle. Scripts will be developed for control modification, configuration verification, legitimate-use testing, attack execution, evidence collection, result storage, and environment restoration.

Proxmox snapshots will provide the known starting states required for repeatable experimentation. The intended automated lifecycle is:

Restore → Apply Ablation → Verify → Legitimate Test → Attack → Establish Ground Truth → Collect Evidence → Store Results → Reset

This automation will reduce variation between repetitions and make it possible to execute larger experimental matrices as the project expands.

The complete testbed definition, scripts, configuration states, experiment metadata, raw evidence, analysis procedures, and documentation will be maintained so that another researcher can reproduce the experiment.

Analysis and Classification

Results will be compared across the four experimental conditions. Primary measurements will include attack success rate, furthest attack progression, number of attempts, time to outcome, legitimate-access success, operational effects, and completeness and accuracy of system evidence.

Each tested CIS recommendation will ultimately be classified as:

- Supported: The recommendation produced a repeatable change in the defined attack outcome.
- Unsupported: The recommendation did not produce the hypothesized change.
- Conditional: The recommendation affected the outcome only when another configuration or environmental condition was present.
- Inconclusive: The available experimental evidence was insufficient to support a defensible conclusion.

Null and unsupported results will be retained because they provide information about the actual relationship between configuration recommendations and attack behavior.

Extension to the Larger Research Project

The pilot testbed is intended to establish the feasibility of a broader empirical security-configuration research framework. Once the experimental process is validated, the same methodology can be extended to additional CIS recommendations, attack behaviors, system configurations, and Linux environments.

The resulting research pipeline can be represented as:

CIS Recommendation → System Configuration → ATT&CK Behavior → CWE/CVE Relationship Where Applicable → Controlled Experiment → Attack Outcome → Operational Impact → Logging/Provenance Evidence → Empirical Classification

The long-term objective is therefore not simply to determine whether a CIS-hardened system is more secure than a default system. Rather, the project seeks to determine **which configuration recommendations contribute to particular defensive outcomes, under what conditions those contributions occur, what operational costs accompany them, and what observable system evidence is produced.**

This framework provides a foundation for developing a structured dataset connecting security configuration guidance with experimentally observed cybersecurity outcomes. Such a dataset could support future research and tools that provide administrators with more contextual information than configuration-compliance status alone, including the likely security benefit, operational tradeoffs, attack relationships, and confidence supported by experimental evidence.